Measuring and Improving the Security Posture of IEC 61850 Substations against Supply Chain Attacks

Onur Duman*, Azadeh Tabiban†, Lingyu Wang*, Mourad Debbabi*
*Security Research Center, Concordia University, Montréal, Québec, Canada
† Computer Science Department of the University of Manitoba

***Abstract*—Supply chain attacks exploit vulnerabilities injected into devices before their shipment or during firmware updates, and represent a significant security threat to substations. Preventing such attacks through the naïve solution of purchasing devices only from trusted vendors may not always be feasible (e.g., due to operational constraints of an operator being bound to particular vendors). Furthermore, in many cases, the effectiveness of applying ad-hoc hardening options can be limited, while it may not be feasible to deploy all possible security mechanisms due to budget constraints. Finally, manually assessing and applying different hardening options while respecting a given budget is usually very challenging for system operators and can be prone to human error. In this paper, we develop HFS, a hardening system to measure and optimally improve the security posture of substations against supply chain attacks. First, HFS provides a hardening mechanism for securing substations, while considering the budget and operational constraints. Second, HFS provides a visual framework that allows operators to generate attack graphs and manually experiment with various hardening options. We validate the effectiveness of HFS based on several scenarios including the case in which supply chain attacks are mitigated by fixing non-supply chain vulnerabilities. Our simulation results demonstrate that HFS significantly improves the security posture of substations against supply chain attacks even with limited supply chain-related hardening options.**

I. Introduction

Substations are typically responsible for protecting, monitoring, and controlling the smart grid. Therefore, compromising substations may lead to major damages, such as cascading failure of transmission lines [1] or blackouts. This was evident in the 2015 Ukraine attack, in which compromising seven substations led to a blackout affecting 225,000 residents for several hours [2]. To cause such incidents, attackers typically exploit the existing vulnerabilities of substations. In particular, supply chain-related vulnerabilities may exist since a smart grid substation consists of multiple levels (i.e., the substation level, bay level, and process level) with several devices at each level, which implies a large attack surface [3]. Moreover, in many cases, operators have to adopt devices from less commonly trusted vendors [4], due to their special needs or the limited availability of those devices. Finally, even trusted vendors can be compromised by supply chain attacks. For instance, in the SolarWinds (a well-known developer of network management systems) security incident [5], attackers deployed malware as part of the software update downloaded by many legitimate vendors.

Although supply chain attacks present a major threat to the security posture of substations, they have attracted limited attention in the smart grid research domain. The naïve solution of replacing less trusted vendors may not always be practically feasible due to operational constraints, such as limited availability of devices and prohibitive costs. Most existing works focus on defining supply chain security metrics [6], threat reporting among supply chain stakeholders [7], and demonstrating the improvement of the security posture using non-supply chain hardening options [4]. The only systematic solution for improving the security posture of IEC 61850 substations against supply chain attacks [4] falls short in identifying the cost-effective hardening options and requires the manual generation of attack graphs to find such hardening options. In the following, we present a motivating example to further highlight the need for a system that can optimally harden IEC 61850 substations against supply chain attacks.

A. Motivating Example

Fig. 1 illustrates an example substation (left) [8] and the challenges faced by an operator (right) to improve the security posture of the substation. Suppose that the operator is mostly concerned about attacks aiming at tripping circuit breakers [9] (as it would lead to overloading transmission lines and their subsequent failure). Assume that two attackers with and without the capability of exploiting supply chain vulnerabilities (i.e., *supply chain attacker* and *non-supply chain attacker*, respectively, in Fig. 1) can access the substation through the Wide Area Network (WAN). To start tripping circuit breakers, the non-supply chain attacker first needs to infiltrate into the substation network by compromising the Gateway ($Node6$). Next, the attacker can compromise the HMI ($Node1$) and the Workstation ($Node2$), and finally, compromise the Protection Intelligent Electronic Device (IED), $Node7$. However, the supply chain attacker can start tripping circuit breakers by simply compromising the Workstation ($Node2$) and the protection IED ($Node7$) through an existing supply chain vulnerability that the attacker has already planted inside the Workstation ($Node2$) to open a backdoor and a zero-day vulnerability, respectively.

To improve the security posture of the substation against such attackers, the operator first needs to establish a model to capture potential vulnerabilities in the substation and how

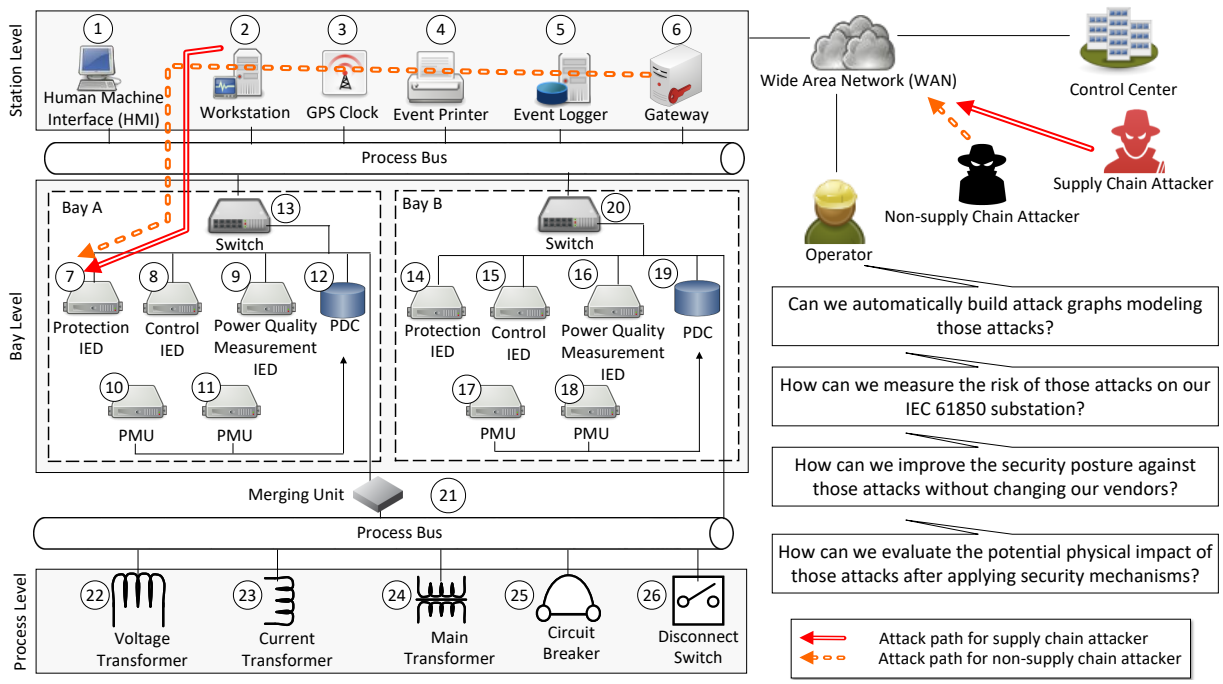


Fig. 1: An example substation and the attack paths targeting Protection IEDs (left); challenges of improving the security posture of the substation against the supply chain attacker and non-supply chain attacker (right).

an attacker might combine them to gain access, which can be a challenging task without automated tools. Moreover, to identify the optimum hardening options, the operator needs to evaluate and compare the improvement of security metrics that can be achieved by applying different hardening options. Such hardening options must also respect the limited budget and operational constraints of the operator (e.g., certain connections cannot be behind a firewall). However, this can be a daunting task if done manually, especially considering a large number of hardening options and constraints (detailed in Section III-B3). For instance, protecting HMI with a firewall may prevent the non-supply chain attacker, but it does not block the attack path of the supply chain attacker. Moreover, replacing the vendor of the HMI for hardening the substation may not be feasible when there are constraints bounding the operator to a single vendor. Finally, considering the cyber-physical nature of substations, the operator may additionally need to analyze the physical impact of cyber attacks after hardening to identify critical IEDs controlling transmission lines.

To address those challenges, we propose in this paper the Hardening Framework for Substations (*HFS*), an interactive system for improving the security posture of substations in the presence of budget and operational constraints. Specifically, HFS enables operators to automatically generate attack graphs, calculate security metrics, and reason about different hardening options through a visualization interface. Behind the scenes, HFS hardens substations against supply chain attacks by maximizing the security posture in a cost-effective manner using multi-objective optimization and allows analyzing the potential physical impacts of cyber attacks. To support scenarios where there only exists limited supply chain-related hardening options, HFS is designed to mitigate supply chain attacks by applying a mixture of supply chain-related hardening options (e.g., replacing vendors) and non-supply chain-related hardening options (e.g., adding firewalls and relocating services).

In summary, our main contributions are as follows:

- To the best of our knowledge, HFS is the first interactive system specifically designed to improve the security posture of substations against supply chain attacks under given cost and operational constraints using multi-objective optimization. A unique feature of HFS is it can still mitigate supply chain attacks even if supply chain-related options, such as replacing vendors or upgrading devices, are not possible.
- To realize HFS, we first design a module that allows the operator to automatically generate attack graphs based on the configurations of the substation. Second, our metric calculation module utilizes multiple security metrics for measuring the security posture of IEC 61850 substations against different types of attacks. Finally, we design a Markov Decision Process (MDP) generation module to analyze the physical damage of cyber attacks.
- We validate the effectiveness of HFS based on several scenarios representing different real-world substations. Our simulation results show that HFS effectively improves the security posture of substations against supply chain attacks while allowing the reduction of monetary costs under different operational constraints.

The preliminary version of this paper [4] is limited to improving the security posture based on a single security metric, which has been significantly extended in this work with multiple objectives, constraints, hardening option visualization, MDP modeling of physical damage, etc. Specifically,

our major extensions are as follows:

1) To enable efficient threat modeling, we first design and implement an interactive system that can automatically generate attack graphs and can also allow the operator to fine-tune or update the model. (Section III-B1).
2) We design and implement an approach that adopts multi-objective optimization to enhance the security posture according to multiple security metrics and with respect to budget and operational constraints (Section III-B3).
3) To facilitate identifying optimal hardening options, we design and implement a module that visualizes all hardening options (Section III-C4) and determines the ones that can be applied considering the specified constraints (Section III-C5).
4) To further assist the operator, we also build a module that visualizes the physical impact of different hardening options (Section III-C6).
5) To accommodate the newly added functionalities, we design and implement our approach based on a new architecture and showcase the effectiveness of our new framework through several use cases (Section IV).
6) We demonstrate the applicability of our approach by measuring its execution time and effectiveness in different scenarios through simulations (Section V).

The rest of this paper is organized as follows. Section II provides background information. Section III details our solution, HFS. Section IV provides several use cases of our solution, and Section V shows our simulation results. Section VI reviews the related work. Finally, Section VII concludes the paper.

II. Preliminaries

This section provides background on supply chain attacks, attack graphs, security metrics, and network hardening.

A. Supply Chain Attacks

Supply chain attacks exploit vulnerabilities that are deliberately injected either by a malicious vendor [10] or by attackers who compromise the vendor's distribution channel [5]. Supply chain vulnerabilities may autonomously spread and activate themselves and can be regularly updated to remain stealthy [6]. Furthermore, patching such vulnerabilities is typically challenging as it may require physical modifications (e.g., replacing chipsets [6]). Finally, similar to zero-day vulnerabilities [11], supply chain vulnerabilities are typically not known to operators before they are exploited. While the former usually exists due to developers' lack of security awareness, the latter is intentionally developed and injected into the vendor's distribution channel [6]. Given such unique characteristics, it leads to new challenges to defend substations against supply chain vulnerabilities.

B. Attack Graph

Attack graphs visualize inter-dependent actions taken by attackers to compromise critical assets in the network [12], [13]. Fig. 2 shows an example attack graph depicting the steps that an attacker could take to compromise the Protection IED ($Node7$) of the substation network depicted in Fig. 1 and start tripping circuit breakers. An attack graph consists of two types of nodes: *exploits* and *conditions*.

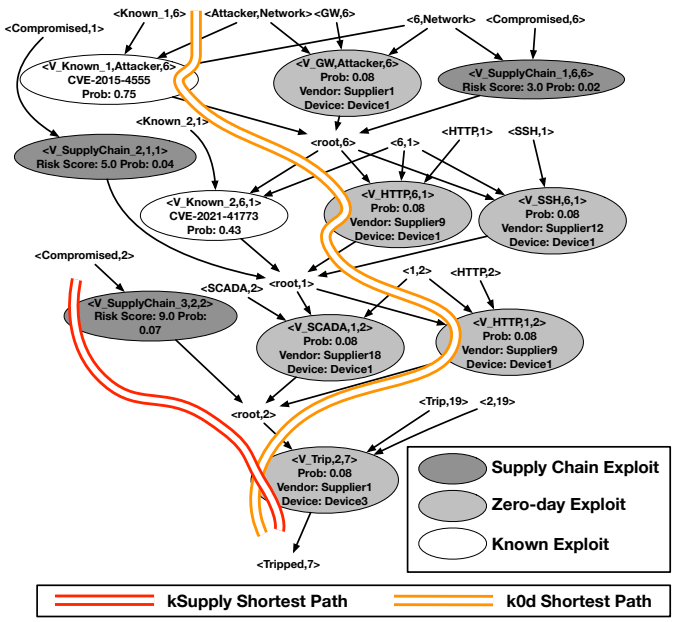


Fig. 2: Attack graph for maliciously tripping circuit breakers.

Exploits (shown by ovals) represent vulnerabilities of different components in a substation. In this paper, we categorize exploits into three main groups: known, zero-day, and supply chain exploits. Known exploits are shown by white ovals describing the source/destination hosts of an attacker exploiting each vulnerability, their corresponding CVE [14], and probability. For example, in Fig. 2, the exploit $\langle V_Known_1, Attacker, 6\rangle$ represents the exploit of a known vulnerability in substation gateways that allows an attacker to remotely perform arbitrary code execution attack [15] on $host6$. Since this vulnerability has the Common Vulnerability Scoring System (CVSS) Score of 7.5 [15], the probability of exploiting it can be represented as 0.75[1] (i.e., 7.5 divided by the maximum possible CVSS score 10.0 [16]). Zero-day exploits are shown by light gray ovals, which describe the source/destination hosts of the attacker, the probability of the exploit as well as the device and its vendor running the vulnerable service instance. For example, in Fig. 2, the exploit $\langle V_HTTP, 6, 1\rangle$ represents the exploit of an HTTP service instance running on $Device1$ of $Supplier9$. Two zero-day exploits are considered equivalent when they exist in the same service instance running on the identical device of a given vendor [11]. For instance, in Fig. 2, the exploits $\langle V_HTTP, 6, 1\rangle$ and $\langle V_HTTP, 1, 2\rangle$ are equivalent as they correspond to an (unknown) vulnerability in the same HTTP service instance running on the same device and supplier (i.e., $Device1$ and $Supplier9$, respectively). As a zero-day vulnerability is unknown, its probability takes a nominal value of 0.08 [16]. Supply chain exploits (e.g., $\langle V_SupplyChain_1, 6, 6\rangle$ in Fig. 2) are shown by dark gray

[1]The probability of exploiting a known vulnerability is calculated as $\frac{CVSSScore}{10.0}$ [16].

ovals describing the source/destination of an attacker exploiting supply chain vulnerabilities, their corresponding Supply Chain Risk Score (SCR) [4] and probability. The probability of a supply chain exploit is typically smaller than a zero-day vulnerability (i.e., $0.08 \times \frac{SCR}{10.0}$) [4]. An attacker can exploit a vulnerability when all of its preconditions are satisfied. For instance, in Fig. 2, an attacker can exploit the vulnerability $\langle V_SCADA, 1, 2\rangle$ when the $SCADA$ server is running on $host2$, the attacker has compromised $host1$, and $host1$ is connected to $host2$.

Conditions (shown by borderless texts) represent what needs to be satisfied for exploiting vulnerabilities and are typically categorized into three main groups: connectivity, privilege, and service existence conditions [17]. Connectivity conditions represent the connection between two nodes (e.g., in Fig. 2, $\langle 1, 2\rangle$ represents the connection between $host1$ and $host2$). Privilege conditions represent the privilege gained over a host (e.g., in Fig. 2, $\langle root, 1\rangle$ represents gaining root privilege over $host1$). Service existence conditions represent a service running on a host (e.g., in Fig. 2, $\langle SCADA, 2\rangle$ represents $SCADA$ service running on $host2$). A condition is satisfied when either of its parent exploits is satisfied. To illustrate, in Fig. 2, the privilege condition $\langle root, 2\rangle$ is satisfied when the attacker exploits either $\langle V_SCADA, 1, 2\rangle$, $\langle V_HTTP, 1, 2\rangle$ or $\langle V_SupplyChain_3, 2, 2\rangle$. Any condition with no parent exploit is called an initial condition (e.g., $\langle HTTP, 1\rangle$ in Fig. 2). The goal condition (e.g., $\langle Tripped, 7\rangle$ in Fig. 2) represents the end goal of the attacker.

C. Security Metrics

1) Supply Chain Risk Score (SCR): An IEC 61850 substation network may include devices from less commonly trusted vendors. Therefore, supply chain risk factors are defined [4] to consider the origin and the producer of the product as well as the inclusion of the product in the common criteria [18]. Based on those risk factors and inspired by CVSS [14], SCR aims to estimate the severity of supply chain vulnerabilities. Similar to CVSS, SCR categorizes risk factors into three categories: base, temporal, and environmental metrics, which define the characteristics of vulnerabilities that remain steady, vary over time, and depend on the computing environment, respectively [4].

2) Attack Graph-Based Security Metrics: Attack graph-based security metrics are utilized to measure the security posture of critical networks for different kinds of attacks. In this paper, we utilize two attack graph-based security metrics: $k0d$ [11] and $kSupply$ [6].

$k0d$ metric [11] represents the minimum number of zero-day vulnerabilities that an attacker needs to exploit to compromise a critical asset of a given network. Higher values of $k0d$ for a substation network imply higher resilience against zero-day attacks, as exploiting a large number of distinct zero-day vulnerabilities in a given substation is less likely for an attacker. The $k0d$ value of an attack graph is equal to the minimum $k0d$ that is calculated for each of its attack paths [11]. The attack path with the minimum value of $k0d$ is called the $k0d$ *shortest path*. To illustrate, in Fig. 2, the $k0d$ shortest path $\langle V_Known_1, Attacker, 6\rangle \rightarrow \langle V_HTTP, 6, 1\rangle \rightarrow \langle V_HTTP, 1, 2\rangle \rightarrow \langle V_Trip, 2, 7\rangle$ (shown by the orange double line) depicts how an attacker can compromise $host7$ through exploiting the minimum number of distinct zero-day vulnerabilities. This attack path consists of four exploits: two zero-day $HTTP$ exploits in $host1$ and $host2$, a zero-day $Trip$ exploit in $host7$, and a known exploit in $host6$. In calculating $k0d$, the two $HTTP$ exploits of this attack path (corresponding to the same service instance running on $Device1$ of $Supplier9$) are counted as one zero-day exploit, as an attacker capable of exploiting one of those instances would be also able to exploit the other one.

To quantify vulnerabilities in our calculations, we convert the probability of exploiting them into path lengths using the formula $log_{0.08}(Probability\ of\ Exploit)$ (detailed in [17]). Accordingly, the path length for a zero-day vulnerability is $log_{0.08}(0.08) = 1.0$, and the path length for the known vulnerability $\langle V_Known_1, Attacker, 6\rangle$ is $log_{0.08}(0.75) = 0.11$, where 0.75 is the probability of exploiting this known vulnerability. As this attack path contains two distinct zero-day vulnerabilities with path lengths of 1.0 and one known vulnerability with a path length of 0.11, the value of its $k0d$ metric is 2.11. Intuitively, this means that the amount of effort needed from an attacker to compromise the substation network and start tripping circuit breakers using known and zero-day exploits is equivalent to exploiting 2.11 distinct zero-day vulnerabilities.

$kSupply$ [6] metric, which is inspired by $k0d$ metric [11], indicates the minimum number of supply chain vulnerabilities that an attacker needs to exploit for compromising a critical asset in the network (e.g., tripping circuit breakers, $\langle Tripped, 7\rangle$, shown in Fig. 2). A higher value of $kSupply$ means that the substation is more resilient to supply chain attacks as it is less likely that an attacker can exploit a larger number of distinct supply chain vulnerabilities in a given substation. To illustrate, in Fig. 2, an attacker who is capable of exploiting supply chain vulnerabilities can follow the $kSupply$ *shortest path* $\langle V_SupplyChain_2, 1, 1\rangle \rightarrow \langle V_Trip, 2, 7\rangle$ (shown by the red double line). The value of $kSupply$ for this attack path is 2.05 since this attack path contains one supply chain vulnerability, which is equivalent to 1.05 zero-day vulnerabilities ($log_{0.08}(0.07) = 1.05$), and one zero-day vulnerability with the path length of 1.0. Intuitively, this implies that the amount of effort needed from an attacker to compromise the substation network using known, zero-day, and supply chain exploits is equivalent to exploiting 2.05 distinct zero-day vulnerabilities, which is slightly less than in the previous case.

D. Network Hardening

Network hardening refers to applying security mechanisms to the network, such as adding firewalls, diversifying service instances [17], patching known vulnerabilities, relocating services, etc., in an optimal manner. In [19], the authors formulate a single objective genetic algorithm optimization to improve network diversity metrics defined in [17] based on cost constraints (detailed in Section VI). In [20], the

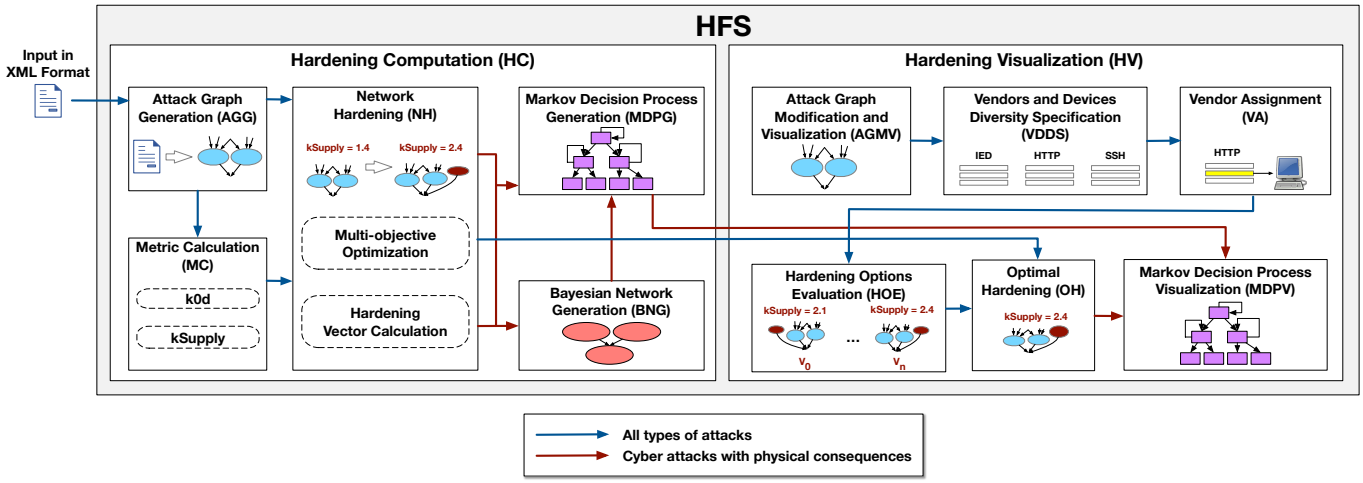


Fig. 3: Overview of HFS.

authors utilize multiple heterogeneous hardening options, such as disabling services and relocating services to improve the security posture of critical networks against zero-day attacks. Heterogeneous hardening options can be applied to protect IEC 61850 substation networks such that supply chain-related and non-supply chain-related hardening options are leveraged to protect those networks against supply chain attacks [4]. To illustrate, for the substation network shown in Fig. 1, the operator can add firewalls, add detection mechanisms, move some services from one host to another, disable some services in some hosts, diversify services [17], and apply firmware upgrades [4] to reduce the severity of supply chain exploits.

III. HFS Methodology

This section provides the detailed methodology of HFS.

A. Overview

HFS enables the identification of optimal hardening options based on the operational and cost constraints of the substation network. Fig. 3 shows an overview of HFS consisting of two main components: Hardening Computation (HC) and Hardening Visualization (HV).

The HC component performs the underlying computations required for improving the security of the substation. To this end, it first generates the attack graph corresponding to a given substation network (Section III-B1) and then calculates the security metrics for the generated attack graph (Section III-B2). Next, HC identifies the optimal hardening options based on the calculated security metrics (Section III-B3). Finally, it leverages the Bayesian Network (Section III-B4) and Markov Decision Process (Section III-B5) to analyze the potential physical impact of cyber attacks before and after hardening.

The HV component enables the interaction of the operator with HC and visualizes the results of hardening. To this end, HV allows the operator to interactively adjust attack graphs (Section III-C1), specify the list of devices for each service (Section III-C2), and assign a vendor and a model for services running on each host (Section III-C3). The operator can also

```
<attack_graph name="SimpleAG" goal="<root,B>" initial="<Attacker,Network>">
  <exploit_node type="unknown" cveid="CVE-XXXX" source="Attacker" target="A" name="SSH"
    vendor="Supplier11" device="Device1">
    <precondition name="<SSH,A>" type="vulnerability"></precondition>
    <precondition name="<A,Network>" type="connection"></precondition>
    <precondition name="<Attacker,Network>" type="privilege"></precondition>
    <postcondition name="<root,A>" type="privilege"></postcondition>
  </exploit_node>
  <exploit_node type="unknown" cveid="CVE-XXXX" source="A" target="B" name="HTTP"
    vendor="Supplier9" device="Device1">
    <precondition name="<HTTP,B>" type="vulnerability" ></precondition>
    <precondition name="<A,B>" type="connection"></precondition>
    <precondition type="privilege" name="<root,A>"></precondition>
    <postcondition type="privilege" name="<root,B>"></postcondition>
  </exploit_node>
</attack_graph>
```

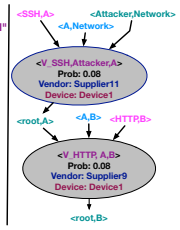


Fig. 4: XML definition (left) of a basic attack graph (right). (Semantically related items have the same color.)

experiment with different hardening options (Section III-C4). Based on the specified values, HV identifies and visualizes the optimal hardening options (Section III-C5) and demonstrates the effectiveness of hardening against cyber attacks with physical consequences (Section III-C6). The rest of this section explains each module of HFS.

B. Hardening Computation (HC)

In this section, we discuss how HC handles attack graph generation, metric calculation, and network hardening.

1) Attack Graph Generation (AGG): AGG module generates attack graphs that capture known, zero-day, and supply chain vulnerabilities corresponding to an IEC 61850 substation. To this end, the AGG module takes its input information in Extensible Markup Language (XML) format that is provided by the operator according to the configuration of the substation (i.e., the set of hosts and their interconnections, the services running on each host, etc.). Fig. 4 shows an example XML file (left) of a basic attack graph (right). Moreover, to support incremental updates over time, HFS allows the operator to interactively adjust the basic attack graph through the following attack graph operations:

Adding a firewall for a connection. Each connectivity condition represented in the attack graph can be placed behind a firewall with a bypass probability that is specified by the operator. Fig. 5 illustrates the addition of a firewall to protect the connectivity condition $\langle 6, 1 \rangle$ in Fig. 2.

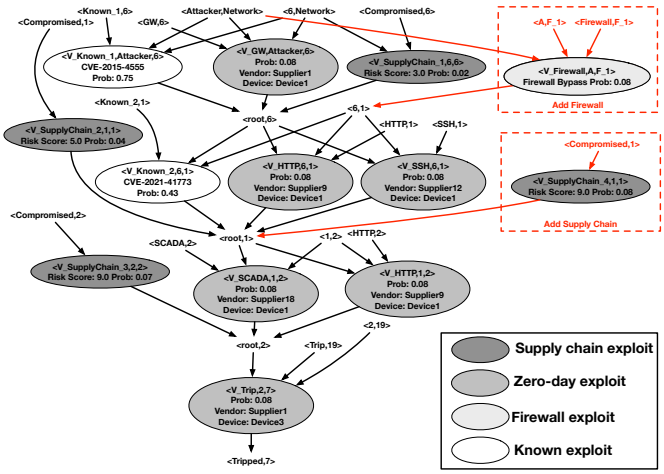


Fig. 5: Attack graph representing the addition of one firewall and one supply chain vulnerability to the attack graph in Fig. 2 (new edges are shown in red).

Adding a host between two connected hosts. A new host with an assigned service can be added between each pair of directly connected hosts, while the connection between the latter may or may not be retained.

Adding a vulnerability to a host. A service with a vulnerability (zero-day, known, or supply chain) can be added to an existing host. Fig. 5 illustrates the addition of a supply chain vulnerability with the risk score of 9.0 to $host1$ in the attack graph shown in Fig. 2.

Adding a detection mechanism to a host. A new detection mechanism with a particular detection rate can be added to one of the existing hosts.

In the next section, we detail how the generated attack graph is adopted for measuring the security posture based on the security metrics.

2) Metric Calculation (MC): This module is responsible for calculating the security metrics, which are $k0d$ [11] and $kSupply$ [6]. For calculating those metrics, the MC module first traverses the attack graph and extracts all attack paths leading to the goal condition. Extracting attack paths is typically done through logical reasoning about the conjunctive and disjunctive relationships between nodes [21]. Conjunction means an attack graph node and its postconditions are included in an extracted attack path if all preconditions of that node are satisfied. For instance, in Fig. 2, the exploit $\langle V_GW, Attacker, 6\rangle$ and its postconditions are included in the extracted attack path when all of its preconditions (i.e., $\langle GW, 6\rangle$, $\langle 6, Network\rangle$, and $\langle Attacker, Network\rangle$) are satisfied, which results in an extracted attack path with the following set of nodes: $\{\langle GW, 6\rangle$, $\langle 6, Network\rangle$, $\langle Attacker, Network\rangle$, $\langle V_GW, Attacker, 6\rangle$, $\langle root, 6\rangle\}$. Disjunction means an attack graph node is included in multiple attack paths as the node can be satisfied if one of its preconditions is satisfied. For instance, in Fig. 2, the node $\langle root, 6\rangle$ can be reached from three different attack paths so it is added to three attack paths with the following sets of nodes:

- $P1$:$\{\langle GW, 6\rangle$,$\langle 6, Network\rangle$,$\langle Attacker, Network\rangle$, $\langle V_GW, Attacker, 6\rangle$,$\langle root, 6\rangle\}$
- $P2$:$\{\langle Known_1, 6\rangle$,$\langle 6, Network\rangle$, $\langle Attacker, Network\rangle$,$\langle V_Known_1, Attacker, 6\rangle$, $\langle root, 6\rangle\}$
- $P3$:$\{\langle Compromised, 6\rangle$,$\langle 6, Network\rangle$, $\langle V_SupplyChain_1, 6, 6\rangle$,$\langle root, 6\rangle$ $\}$

To extract the final attack paths, we recursively perform conjunction and disjunction procedures, till the goal condition is included in the extracted attack paths. Based on the extracted attack paths, MC calculates $k0d$ and $kSupply$ metrics for the entire attack graph. To reduce the complexity of calculations, we leverage a heuristic method similar to [17], which retains only a certain number (h, which is a parameter determined by the operator to trade-off between efficiency and accuracy [17])) of the shortest paths for each privilege condition. For instance, in Fig. 2, the privilege condition $\langle root, 6\rangle$ can be reached through three attack paths, namely $P1$, $P2$, and $P3$, with attack path lengths of $log_{0.08}(0.08) = 1.0$, $log_{0.08}(0.08) = 0.11$, and $log_{0.08}(0.02) = 1.55$, respectively. The h value of two means that the security metrics are calculated based on the two shortest attack paths (i.e., P1 and P2).

3) Network Hardening (NH): This module is responsible for hardening the substation according to the calculated security metrics. In this paper, we categorize hardening options into supply chain-related and non-supply chain-related options. Specifically, supply chain-related options include:

Replacing vendors with more trustworthy ones. This is the most straightforward option to reduce the supply chain risk score. For example, in Fig. 2, a suitable candidate for this option is the HMI ($host1$) from a vendor with a risk score of 5.0. However, in some cases, such a replacement is costly and may not effectively improve the security posture of the network. For example, replacing the vendor of HMI with a more trustworthy one does not increase the value of $kSupply$ since the supply chain vulnerability in HMI ($\langle V_SupplyChain_2, 1, 1\rangle$ in Fig. 2) is not on the shortest $kSupply$ attack path.

Upgrading the vendor hardware. An older product of a vendor is more likely to contain supply chain vulnerabilities with a high SCR due to its potentially longer exposure to attackers. Upgrading such old products with newer alternatives equipped with more security measures may reduce the risk of supply chain vulnerabilities. For instance, according to [22], new products with stronger hardware security measures can improve the overall security posture of an enterprise by 55%.

Upgrading the vendor firmware. Upgrading firmware can sometimes patch existing supply chain vulnerabilities, which reduces the SCR. For instance, according to [23], 60% of security breaches are linked to unapplied security patches. However, this option can also be a double-edged sword as applying a firmware upgrade may decrease the security posture (e.g., in the SolarWinds case [5], the update channel of the vendor was hijacked by attackers).

Additionally, HFS leverages non-supply chain-related hardening options. Although those options do not directly improve the SCR of supply chain vulnerabilities, they may still improve the value of $kSupply$, and thus improve the overall security

posture of substations against supply chain attacks. Non-supply chain-related hardening options include:

Adding firewalls. Each connectivity condition (e.g., $\langle 6, 1\rangle$ in Fig. 2) can be placed behind a firewall, which requires the attacker to circumvent that firewall before attacking the protected services.

Adding detection mechanisms. A detection mechanism, with a particular detection rate, can be added to the privilege conditions of each host to prevent attackers from gaining additional privileges. Even though detection mechanisms do not directly improve the security metrics that are based on the shortest attack paths (e.g., $k0d$ and $kSupply$), they may reduce the probability of the attacker gaining additional privileges as the attacker attempts to evade the detection [8].

Patching known vulnerabilities. Known vulnerabilities (e.g., $\langle V_Known_1, Attacker, 6\rangle$ in Fig. 2) can be removed by applying relevant security patches or upgrading the system [24].

Diversifying components. Utilizing a diverse set of vendors or different service instances of the same vendor is an effective hardening option against known, zero-day, and supply chain vulnerabilities. One reason is that different instances are less likely to have shared vulnerabilities that can be exploited by an attacker to compromise multiple hosts running those instances [17].

Disabling services. Disabling an unnecessary service may improve the security posture of the substation [24]. To illustrate, in Fig. 2, by disabling $HTTP$ service in HMI, we can remove the zero-day vulnerability $\langle V_HTTP, 6, 1\rangle$. This hardening option can be utilized when it does not affect the overall functionality of the substation according to the operator.

Relocating services between hosts. Relocating services (e.g., moving a critical service to a host that is protected by a firewall) may improve the security posture of the substation [20]. This hardening option can be utilized when it does not affect the overall functionality of the substation according to the operator.

Each hardening option is associated with a monetary cost. An operator can specify the allowed budgets and various costs (e.g., to replace, maintain, and repair pieces of equipment) associated with hardening options e.g., based on Gartner's total cost of ownership [25]. Although calculating the exact cost of each hardening option may not be feasible prior to hardening, even a rough estimation is usually useful in identifying and choosing the proper hardening options. As an example, the operator can estimate that adding a firewall costs around 5300 dollars, as purchasing a firewall costs around 5000 dollars [26], and the labor costs around 300 dollars.

Additionally, an operator may need to consider the operational constraints. For instance, in some cases, an operator may be bound to a specific vendor, which prevents him/her from using devices from other vendors.

By considering hardening options, costs, and constraints, we can formulate the hardening as a multi-objective optimization problem as follows:

$$
\begin{aligned}
\max \quad & (\alpha_1 \times k0d) + (\alpha_2 \times kSupply) \\
\min \quad & OC \\
\text{s.t.} \quad & \alpha_1 + \alpha_2 = 1.0 \\
(1) \quad & OC \leq Q \\
(2) \quad & COF \leq Q_f \\
(3) \quad & NOF \leq F_{limit} \\
(4) \quad & \forall f \epsilon F, f \notin CTCF \\
(5) \quad & COD \leq Q_d \\
(6) \quad & NOD \leq D_{limit} \\
(7) \quad & \forall d \epsilon D, d \notin HWCBWD \\
(8) \quad & COP \leq Q_p \\
(9) \quad & NOP \leq P_{limit} \\
(10) \quad & \forall p \epsilon P, p \notin KVCBP \\
(11) \quad & CODIV \leq Q_{div} \\
(12) \quad & NODIV \leq DIV_{limit} \\
(13) \quad & \forall div \epsilon DIV, div \notin STCBD \\
(14) \quad & COS \leq Q_s \\
(15) \quad & NOS \leq S_{limit} \\
(16) \quad & \forall s \epsilon S, s \notin SCVTCM \\
(17) \quad & COM \leq Q_{mov} \\
(18) \quad & CODIS \leq Q_{dis}
\end{aligned}
$$

Specifically, the objective functions are to maximize the weighted average of metrics (specified after the term max in the optimization formula) and minimize the overall cost (OC, specified after the term min in the optimization formula) according to budget and operational constraints where α_1 and α_2 are the weights for $k0d$ and $kSupply$, respectively, and represent the relative importance of each metric in improving the security posture. The optimization formula also provides the following list of constraints and allows the operator to select those that are relevant to their substation according to the available budget, and operational constraints.

(1) Overall cost (OC) cannot exceed Q.
(2) Cost of the added firewalls (COF) cannot exceed Q_f.
(3) Number of the added firewalls (NOF) cannot exceed F_{limit}.
(4) None of the connectivity conditions that are protected by firewalls (F) can be in the set of connections not intended to be protected by a firewall ($CTCF$).
(5) Cost of the added detection mechanisms (COD) cannot exceed Q_d.
(6) Number of the added detection mechanisms (NOD) cannot exceed D_{limit}.
(7) None of the hosts with the added detection (D) can be in the set of hosts not intended to have a detection mechanism ($HWCBWD$).
(8) Cost of patching (COP) cannot exceed Q_p.
(9) Number of applied patches (NOP) cannot exceed P_{limit}.
(10) None of the known vulnerabilities that are patched (P) can be in the set of known vulnerabilities that do not currently have a patch ($KVCBP$).
(11) Cost of diversity ($CODIV$) cannot exceed Q_{div}.
(12) Number of diversified services ($NODIV$) cannot exceed DIV_{limit}.
(13) None of the diversified services (DIV) can be in the set of services not intended to be diversified ($STCBD$).

(14) Cost of supply chain-related hardening options (COS) cannot exceed Q_s.
(15) Number of applied supply chain-related hardening options (NOS) cannot exceed S_{limit}.
(16) None of the supply chain exploits for which supply chain-related hardening options are applied (S) can be in the set of supply chain exploits that cannot be modified ($SCVTCM$).
(17) Cost of moving services (COM) cannot exceed Q_{mov}.
(18) Cost of disabling services ($CODIS$) cannot exceed Q_{dis}.

To solve this optimization problem, we leverage Pymoo [27] (an open-source Python optimization library) and its implemented Non-dominated Sorting Genetic Algorithm (NSGA)-II. We chose NSGA-II as it is a multi-objective optimization algorithm, and it does not require reference points to start the optimization. NSGA-II provides the Pareto front of the hardening problem as a set of results in which each result is not better than any other results in terms of both metrics and costs. To adopt NSGA-II, we need to represent each hardening solution as a gene (a vector of integers representing a possible solution). To this end, we first represent the set of all possible ways of hardening a substation as a *Hardening Dictionary* [4]. For instance, Table I shows the Hardening Dictionary for the attack graph in Fig. 2 with three connections, four hosts, two known vulnerabilities, six services running on hosts, and three supply chain exploits, the sum of which corresponds to 18 rows of the Hardening Dictionary. A hardening vector [4] refers to one possible solution according to the Hardening Dictionary. For instance, the hardening vector $[True, 0, 0, True, 0, 0, 0, 0, 0, 0, 0, 0, 0, 0, 0, 0, 0, 0]$ refers to protecting the connectivity condition $\langle 6, 1\rangle$ by a firewall and adding a detection mechanism to $host6$.

Index	Explanation	Possible Values	Hardening Option Category
0	Place connection $\langle 6, 1\rangle$ behind a firewall?	True or False	Adding firewalls
1	Place connection $\langle 1, 2\rangle$ behind a firewall?	True or False	
2	Place connection $\langle 2, 7\rangle$ behind a firewall?	True or False	
3	Add detection on $host6$?	True or False	Adding detection mechanisms
4	Add detection on $host1$?	True or False	
5	Add detection on $host2$?	True or False	
6	Add detection on $host7$?	True or False	
7	Patch the known vulnerability $\langle V_Known_1, Attacker, 6\rangle$?	True or False	Patching known vulnerabilities
8	Patch the known vulnerability $\langle V_Known_2, 6, 1\rangle$?	True or False	
9	Replace GW on $host6$ with which instance (D) from which vendor (S)?	Keep, (D_2, S_1), (D_1, S_2), (D_1, S_3), (D_2, S_3), (D_1, S_4)	Diversifying services
10	Replace $HTTP$ on $host1$ with which instance (D) from which vendor (S)?	Keep, (D_1, S_7), (D_1, S_8), (D_1, S_10)	
11	Replace SSH on $host1$ with which instance (D) from which vendor (S)?	Keep, (D_1, S_11), (D_1, S_13), (D_1, S_14)	
12	Replace $SCADA$ on $host2$ with which instance (D) from which vendor (S)?	Keep, (D_1, S_16), (D_1, S_17), (D_1, S_3)	
13	Replace $HTTP$ on $host2$ with which instance (D) from which vendor (S)?	Keep, (D_1, S_7), (D_1, S_8), (D_1, S_10)	
14	Replace $TRIP$ (Protection IED) on $host7$ with which instance (D) from which vendor (S)?	Keep, (D_2, S_1), (D_1, S_2), (D_1, S_3), (D_2, S_3), (D_1, S_4)	
15	Apply which supply chain-related hardening option for $\langle V_SupplyChain_1, 6, 6\rangle$?	None, Hardware Update, Firmware Update	Supply Chain-Related Hardening Options
16	Apply which supply chain-related hardening option for $\langle V_SupplyChain_2, 1, 1\rangle$?	None, Hardware Update, Firmware Update	
17	Apply which supply chain-related hardening option for $\langle V_SupplyChain_3, 2, 2\rangle$?	None, Hardware Update, Firmware Update	

TABLE I: Hardening Dictionary for the attack graph in Fig. 2.

4) Bayesian Network Generation (BNG): In addition to finding the shortest attack paths, attack graphs can be leveraged to calculate the probability of compromising each host [17]. To this end, the BNG module first builds a Bayesian network with the same structure as a given attack graph. Next, it calculates the probability of compromising each host based on the obtained Bayesian network.

5) Markov Decision Process Generation (MDPG): Although attack graphs enable improving the security posture by identifying the shortest attack paths for compromising critical hosts, they do not consider the physical damage that an attacker can cause. To address this, MDPG leverages Markov Decision Process (MDP) [28]–[30] to model the attacker as an agent aiming to maximize the potential physical damage. A typical MDP consists of sets of states, actions, probability of transitions between states, rewards for each state, and a discount factor [31]. To allow identifying critical security states, the MDPG module first generates an MDP based on the attack graph, where states represent the compromised hosts of the substation and probabilities of transitions between the states are obtained. Next, MDPG calculates the rewards based on the total load on transmission lines using a reward function [28]. To analyze the impact of hardening on potential physical damages, the operator can evaluate the MDP model generated before and after hardening for different optimal hardening vectors previously identified by the NH module.

C. Hardening Visualization (HV)

In this section, we discuss how the Hardening Visualization (HV) module enables an operator to interact with HFS.

1) Attack Graph Modification and Visualization (AGMV): This module allows the operator to load a basic attack graph (e.g., Fig. 4) and extend it to model and visualize potential attacks against their substation. We show a screenshot of the AGMV interface in Fig. 6. Through AGMV, the operator first provides an XML file as the input for generating a basic attack graph model (e.g., the XML file in Fig. 4 (left)) and then interactively modifies this basic configuration using attack graph operations described in Section III-B1.

2) Vendors and Devices Diversity Specification (VDDS): This module allows the operator to manage the list of possible instances and vendors for each service. Such a list is used by the hardening option *Diversifying Components*. We show a screenshot of the VDDS interface in Fig. 6. Through VDDS, the operator can add a new service, add a new vendor and instance for an existing service, delete an existing instance of a service, and delete an existing service.

3) Vendor Assignment (VA): This module allows the operator to assign different instances of a service to each host based on the list of vendors and devices provided to the VDDS module. We show a screenshot of the VA interface in Fig. 6. After assigning a new service instance to a host, VA automatically triggers the MC module to update the values of security metrics. For instance, once the operator changes the instance ($Supplier9$, $Device1$) of $HTTP$ service in $host1$ to instance ($Supplier7$, $Device1$), the value of $k0d$ increases from 2.11 to 3.11.

4) Hardening Options Evaluation (HOE): This module allows the operator to interactively apply hardening vectors according to the Hardening Dictionary generated by the NH module (such as Table I). We show a screenshot of HOE in Fig. 6. The operator can select and apply any hardening vector in the Hardening Dictionary and evaluate its impact on the value of security metrics. For

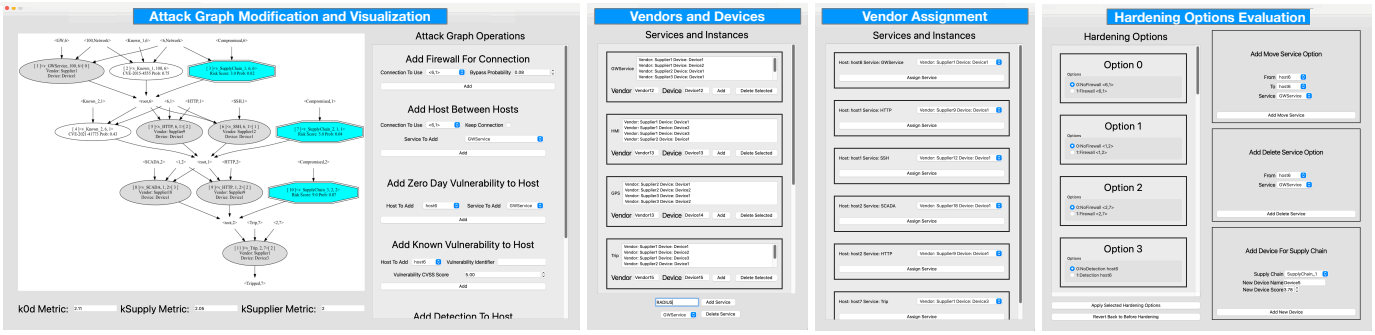


Fig. 6: AGMV, VDDS, VA, and HOE modules of HFS.

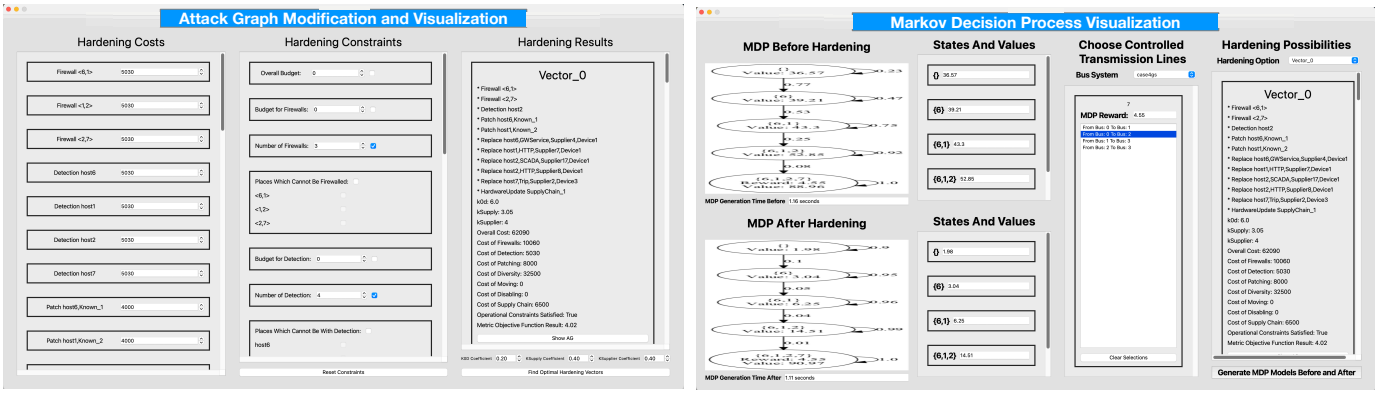


Fig. 7: OH and MDPV modules of HFS.

instance, to evaluate the impact of the hardening vector $[True, 0, 0, True, 0, 0, 0, 0, 0, 0, 0, 0, 0, 0, 0, 0, 0]$, the operator selects *Firewall* $\langle 6, 1\rangle$ and *Detection* $host6$ from the list of hardening options. Additionally, the operator can add hardening options for moving a service from one host to another, disabling a service (non-supply chain-related options), and replacing vendors (supply chain-related options).

5) Optimal Hardening (OH): This module allows the operator to specify the cost of different hardening options and constraints (e.g., the operator may specify a total available budget in dollars), and the weights for different security metrics as mentioned in Section III-B3. We show a screenshot of the OH module in Fig. 7. OH identifies the optimal hardening vectors based on the specified values and visualizes them along with their corresponding hardening options, and the cost of the hardening vectors and their hardening options. Additionally, OH shows the calculated values of security metrics for optimal hardening vectors and demonstrates whether the hardening option satisfies the specified constraints.

6) Markov Decision Process Visualization (MDPV): This module enables evaluating the effectiveness of hardening against potential physical damages. We show a screenshot of MDPV in Fig. 7. Through MDPV, the operator selects the bus system for calculating the load on transmission lines [32]. Next, the operator specifies the set of transmission lines controlled by the sink host of the attack graph (e.g., $host7$ in Fig. 2), and selects any of the identified optimal hardening vectors. Accordingly, MDPV visualizes the MDP models generated before and after hardening.

IV. HFS Use Cases

In this section, we illustrate how HFS can be applied to harden substations under six scenarios with different budget and operational constraints. For all scenarios, HFS can effectively assist the analyst in finding optimal hardening vectors for the substation.

A. No Constraints

In this scenario, an operator with a sufficient budget and no particular operational constraints aims to improve the security posture of the substation against attackers who are capable of exploiting supply chain vulnerabilities (i.e., supply chain attackers). The operator first loads the attack graph using the AGMV module, as shown in Fig. 2, and subsequently, applies the OH module to harden the substation against supply chain attackers. Suppose the operator is more concerned about supply chain attackers than non-supply chain attackers, so he specifies 0.20 for α_1 (weight of $k0d$) and 0.80 for α_2 (weight of $kSupply$). NH identifies the Pareto front of the hardening problem in which no solution is better than others in terms of both the metric objective and the overall cost. Among those solutions, suppose the operator selects the one providing the highest possible metric objective function, despite its potentially higher cost, since the operator is more concerned about the security posture at this stage. As such, the operator chooses the following hardening vector:

- Protect connections $\langle 6, 1\rangle$, $\langle 1, 2\rangle$, $\langle 2, 7\rangle$ by firewalls.
- Patch known vulnerabilities $\langle V_Known_1, Attacker, 6\rangle$ and $\langle V_Known_2, 6, 1\rangle$.

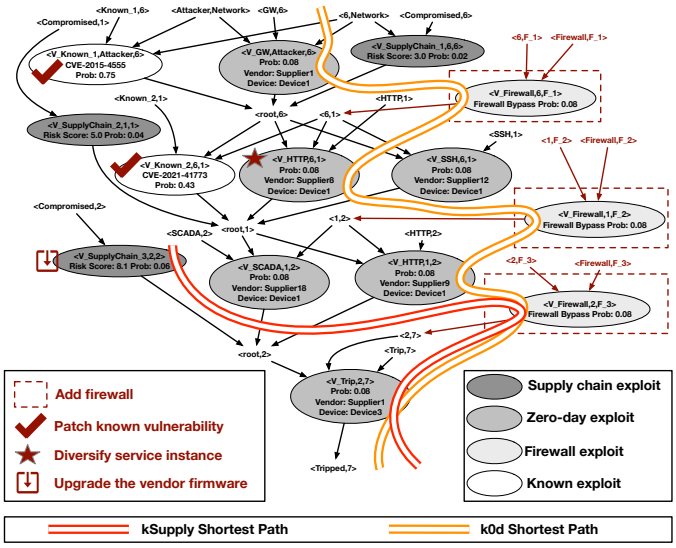


Fig. 8: Optimal hardening for the attack graph in Fig. 2 with no constraints.

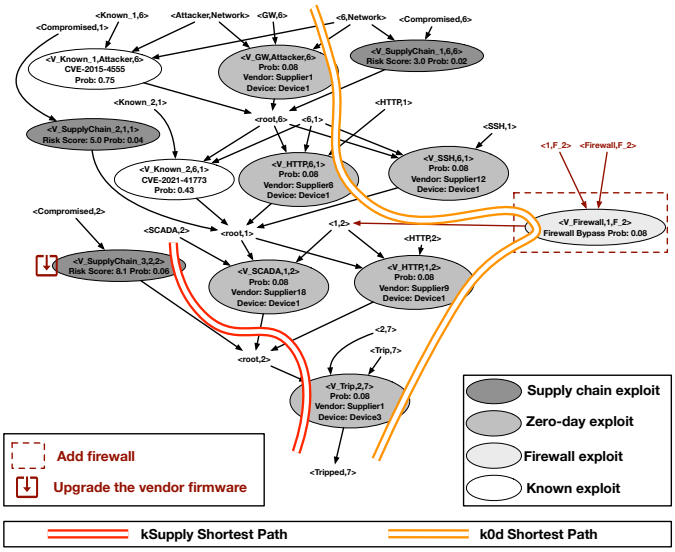


Fig. 9: Optimal hardening for the attack graph in Fig. 2 with overall cost constraint.

- Replace the $HTTP$ service instance on $host2$ with another service instance.
- Apply firmware update on $\langle V_SupplyChain_3, 2, 2\rangle$.

Such a hardening vector increases $k0d$ and $kSuppy$ from 2.11 to 7.0 and from 2.05 to 3.11, respectively. Fig. 8 shows the attack graph after applying this hardening vector and the shortest attack paths.

B. Overall Cost Constraint

In this scenario, an operator with a limited budget aims to improve the security posture against supply chain attackers. Assuming that the cost of protecting each network connection by a firewall is around $5,300$ dollars and applying a firmware update costs around $6,500$ dollars [33], the operator specifies the overall allowed cost to be $13,000$ dollars, which is slightly greater than the cost of protecting two network connections by firewalls. Accordingly, NH identifies the following hardening vector:

- Protect the connection $\langle 1, 2\rangle$ by a firewall.
- Apply firmware update on $\langle V_SupplyChain_3, 2, 2\rangle$.

Applying such a hardening vector increases $k0d$ and $kSupply$ from 2.11 to 3.11 and from 2.05 to 2.11, respectively. Considering the cost of adding a firewall and updating the firmware, the cost of applying this hardening vector is $11,800$ dollars, which is below the overall budget that is specified by the operator. Fig. 9 shows the attack graph after applying this hardening vector with the shortest attack paths.

C. Limited Number of Firewalls

In this scenario, the operator aims to increase the security posture against supply chain attackers with the constraint that only one connection can be protected by a firewall due to the limited availability of technicians capable of installing and maintaining firewalls. The operator does not input any cost constraints. Therefore, he/she specifies the number of firewalls (i.e., one) as a constraint through the OH module. Accordingly, NH identifies the following hardening vector:

- Protect the connection $\langle 2, 7\rangle$ by a firewall.
- Patch known vulnerabilities $\langle V_Known_1, Attacker, 6\rangle$ and $\langle V_Known_2, 6, 1\rangle$.
- Replace HTTP service instance on $host2$ instance with another service instance.
- Apply firmware update on $\langle V_SupplyChain_3, 2, 2\rangle$.

Applying such a hardening vector increases $k0d$ and $kSupply$ from 2.11 to 5.0, and from 2.05 to 3.11, respectively. Fig. 10 shows the attack graph after applying this hardening vector and the shortest attack paths. In this scenario, the NH module successfully identifies the most critical connection (i.e., $\langle 2, 7\rangle$) that should be protected by a firewall and thus, an attacker that exploits the supply chain vulnerability $\langle V_SupplyChain_3, 2, 2\rangle$ can no longer trip the circuit breakers (i.e., the goal condition $\langle Tripped, 7\rangle$ in Fig. 10) through the connection $\langle 2, 7\rangle$.

D. Limited Budget for Diversifying Services

In this scenario, the operator would like to adopt different HTTP services from different vendors on $host1$ and $host2$ to improve the security posture in terms of the $k0d$ metric. However, suppose there are several vendors providing the same service, namely $HTTP$, but with different costs. In this case, the operator applies the NH module to identify the most optimal hardening vector. Assuming that the costs are 6400, 6300, and 6200 dollars (the average cost is around $6,500$ [33]) for replacing the vendor of HTTP service running on $host2$ with $Supplier7$, $Supplier8$, and $Supplier10$, respectively. Next, the operator specifies the available budget for hardening (i.e., $6,400$ dollars) as a hardening constraint. Accordingly, NH identifies the following hardening vector:

- Protect connections $\langle 6, 1\rangle$, $\langle 1, 2\rangle$, and $\langle 2, 7\rangle$ by firewalls.
- Replace HTTP service instance on $host2$ with the instance $Device1$ from $Supplier10$.

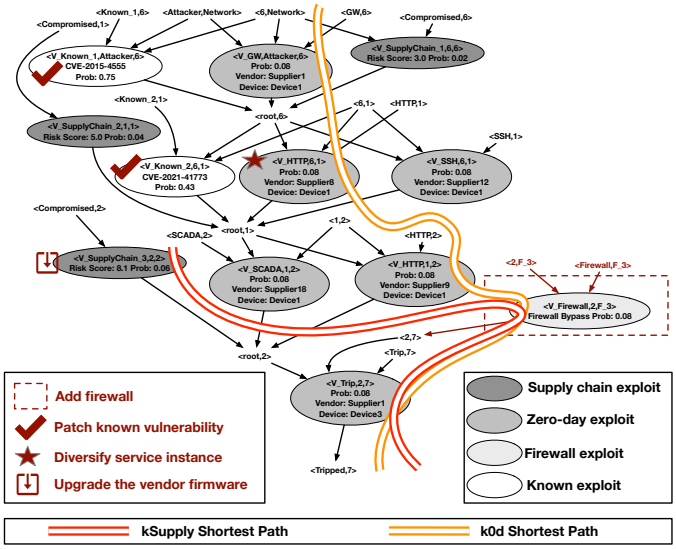


Fig. 10: Optimal hardening for the attack graph in Fig. 2 when only one connection can be protected by a firewall.

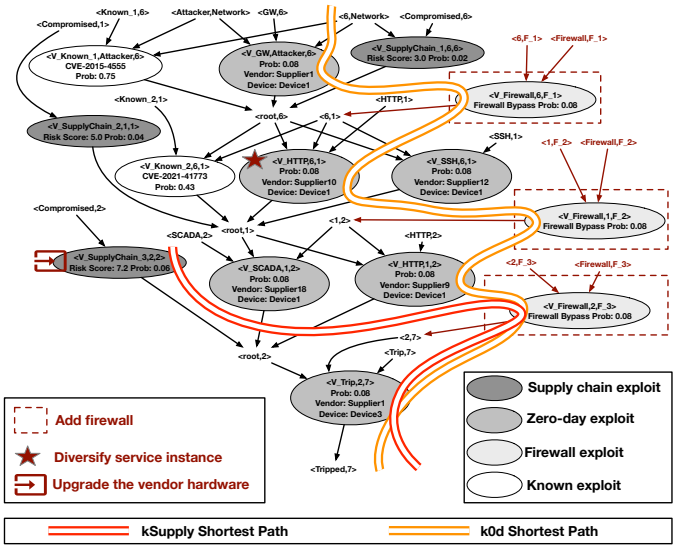


Fig. 11: Optimal hardening for the attack graph in Fig. 2 when there is a limited budget for diversifying services.

- Apply firmware update on $\langle V_SupplyChain_3, 2, 2\rangle$.

Applying such a hardening vector increases $k0d$ and $kSupply$ from 2.11 to 5.45 and from 2.05 to 3.11, respectively. Fig. 11 shows the attack graph after applying this hardening vector and the shortest attack paths.

E. No Available Supply Chain-Related Hardening Options

In this scenario, the operator aims to improve the security posture of a substation against supply chain attackers (i.e., improving the value of kSupply), while there are no available supply chain-related hardening options due to operational constraints. In such circumstances, the operator first specifies α_1 (weight of $k0d$) as 0.0 and α_2 (weight of $kSupply$) as 1.0. Then, he specifies the number of available supply chain-related hardening options (i.e., none) as a constraint, which means that only non-supply chain-related hardening options

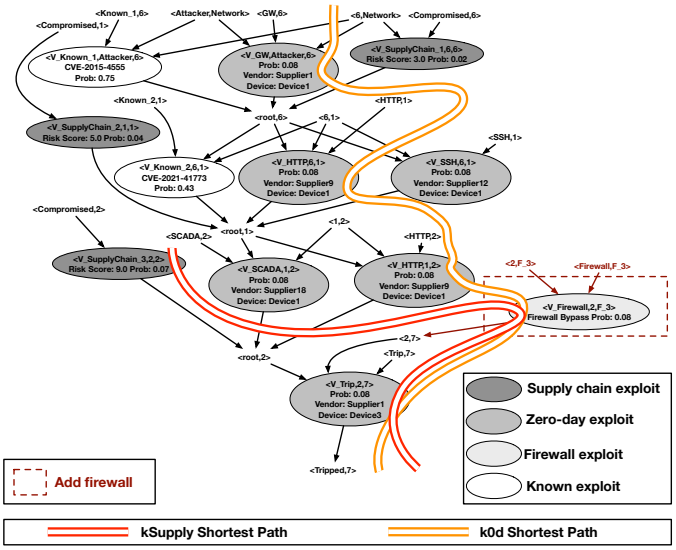


Fig. 12: Optimal hardening for the attack graph in Fig. 2, when supply chain-related hardening options, are not available.

can be applied to the substation. Accordingly, NH identifies the following hardening vector:

- Protect the connection $\langle 2, 7\rangle$ by a firewall.

Applying such a hardening vector increases $kSupply$ from 2.05 to 3.05. Fig. 12 shows the attack graph after applying this hardening vector and the shortest attack paths.

F. Limited Supply Chain-Related Hardening Options

In this scenario, the operator aims to improve the security posture only against supply chain attackers (α_1 is 0.0 and α_2 is 1.0), while he/she realizes that only one supply chain-related hardening option can be utilized due to operational constraints. Therefore, the operator specifies the number of supply chain-related hardening options (i.e., one) as a constraint through the OH module. Accordingly, NH identifies the following hardening vector.

- Protect the connection $\langle 2, 7\rangle$ by a firewall.
- Apply firmware update on $\langle V_SupplyChain_3, 2, 2\rangle$.

Applying such a hardening vector increases $kSupply$ from 2.05 to 3.11. Fig. 13 shows the attack graph after applying this hardening vector and the shortest attack paths.

V. Simulations

To evaluate HFS, we seek to answer the following research questions:

- RQ1: How effective is HFS in improving the security posture of substations?
- RQ2: What are the optimum parameters for NSGA-II multi-objective optimization in HFS?
- RQ3: How scalable is HFS in terms of the latency introduced by its different modules?

Experimental setup.

We perform all simulations on a server with 64 cores and 755 GB memory equipped with Intel (R) Xeon(R) Gold 5218 processors @2.30 GHz. To simulate various substation

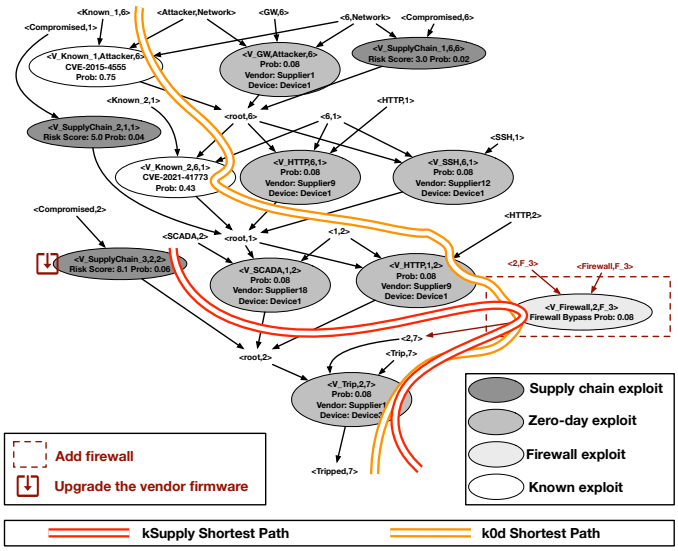


Fig. 13: Optimal hardening for the attack graph in Fig. 2 when only one supply chain-related hardening option is available.

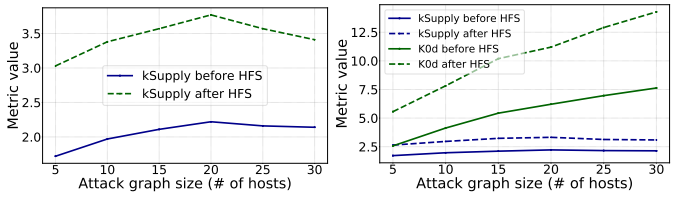
configurations and attack scenarios, we provide a few seed attack graphs to the AGG module to generate 2400 attack graphs (Section III-B1) and we report the average results.

A. *Effectiveness Evaluation*

To answer RQ1, we evaluate the effectiveness of our approach based on the scenarios detailed in Section IV.

No constraints.

Fig. 14a shows that HFS can significantly improve the value of the $kSupply$ metric when there are no constraints. $kSupply$ is greater than 3.0 for all sizes of attack graphs after applying HFS (compared to the initial value of around 2.30). We can also see that there is a minor variation in the value of $kSupply$ as the size of the attack graphs increases. This can be explained by the possibility that the number and location of autonomous supply chain vulnerabilities do not depend on the size of substations.



(a) NH without constraints. (b) NH with OC constraint.

Fig. 14: Effectiveness of NH in scenarios with (a) no constraint and (b) overall cost constraint.

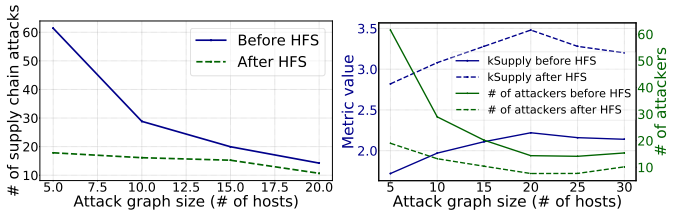
Overall cost constraint.

To measure the effectiveness of our approach under overall cost constraint (OC), we first perform the simulation without constraints and record the average cost of all solutions in the Pareto front as the overall cost constraint. This allows us to specify a relevant cost constraint for each substation since considering the same cost constraint for substations of different sizes may not be realistic.

Fig. 14b shows that HFS improves both $k0d$ and $kSupply$ values, while there is a minor variation in the value of $kSupply$ with the size of the attack graph. $k0d$ improves more significantly with the size of the attack graph due to more possible hardening vectors in larger substations.

Limited number of firewalls.

Fig. 15a demonstrates that our approach is effective against supply chain attackers even when only one connectivity condition can be protected by a firewall. The improvement is more significant for small substations (such as ones with up to 10 hosts). The less significant improvement for larger substations can be explained by the possibility that larger substations require more firewalls to achieve significant improvement in their security posture.



(a) NH with one firewall. (b) NH with a limited budget for diversifying services.

Fig. 15: Effectiveness of NH in scenarios with (a) one available firewall and (b) limited budget for diversifying services.

Limited budget for diversifying services.

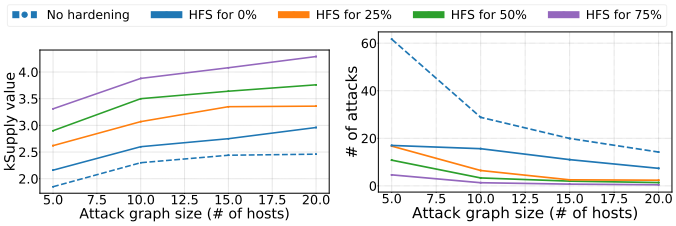
Fig. 15b demonstrates that our approach significantly improves the value of $kSupply$ even with a limited available budget for diversifying services. The value of $kSupply$ is greater than 3.0 for substations with more than 10 hosts. Our approach is more effective against supply chain attackers in smaller substations (reducing the number of successful attacks from 60 to 20). Although the need for diversifying more services in larger substations does not allow an equally significant reduction, HFS still prevents around half of supply chain attackers (i.e., reducing the number of successful attacks from around 20 to 10 in the largest substation).

Limited supply chain-related hardening options.

Fig. 16a shows that HFS improves the value of $kSupply$ with a varying percentage of supply chain exploits that can be used in hardening. As expected, our approach is more effective when hardening options are available for a high percentage of supply chain-related exploits. For instance, the value of $kSupply$ increases from the average value of around 2.6 to 3.9 by addressing 75% of supply chain-related exploits, which demonstrates the importance of available supply chain-related hardening options.

Moreover, our results demonstrate the applicability of HFS to scenarios where there is no available supply chain-related hardening option by increasing the average $kSupply$ value from around 2.2 to 2.55. Note the value of $kSupply$ increases with the size of the attack graph, as achieving the attacker's goal condition in larger substations typically requires meeting more conditions in longer attack paths of their corresponding attack graphs. Fig. 16b shows that HFS prevents around two-thirds (i.e., 40 out of 60) and half (i.e., 10 out of 20) of supply

chain attackers in small and large substations, respectively, even with no available supply chain-related hardening options. In summary, although our approach is more effective under larger percentages of available supply chain-related hardening options, the results generally show a clear reduction of attacks in most cases.



(a) kSupply improvement. (b) Attack reduction.

Fig. 16: Effectiveness of NH in scenarios with different percentages of supply chain-related exploits that can be addressed.

B. Identifying Optimization Parameters for NSGA-II

To answer RQ2, we measure the average security metrics and cost objectives achieved by NSGA-II optimization (Section III-B3) for different values of its parameters (i.e., population size, number of generations, crossover probability, and ETA [34]).

Population size.

Fig. 17a shows that the average metric objective function remains almost similar, and the cost objective function decreases for only around one percent (from 71800 to 71000) with the population size of greater than 150. Therefore, we specify 150 as the population size for the NH module.

Number of generations.

Fig. 17b shows that the average metric objective remains almost similar after 75 generations, and the average cost objective slightly decreases (around 3 percent, from 73600 to 71000) after 75 generations. Therefore, we specify 75 as the number of generations for the NH module.

Crossover probability.

Fig. 17c shows that HFS achieves the highest average metric objective and the lowest cost objective functions with the crossover probability value of 0.9, which we apply in our approach.

ETA.

Fig. 17d shows that the average metric objective and cost objective remain almost similar for the ETA value of greater than 10. Therefore, the ETA value of 10 is chosen for NH.

C. Execution Time

To answer RQ3, we measure the time required by different modules of HFS.

AGG and MC execution time.

Fig. 18a shows that although the time required by AGG increases almost exponentially with the number of hosts, generating the attack graph of a substation with 140 hosts (seven times larger than a typical substation [8]) incurs a negligible overhead of around 0.14 seconds. Similarly, although the time required by the MC module increases almost exponentially as the number of hosts grows, it incurs around four seconds even for a substation with 140 hosts. The execution time of AGG and MC has a similar trend as both processes consist of scanning all attack graph nodes.

MDPG execution time.

Fig. 18b shows that although the time required by MDPG grows almost exponentially with the size of the attack graph, it is around eight seconds for attack graphs with 40 hosts, which is twice the number of hosts in typical substations [8]. One reason for such an exponential increase is that MDPG traverses the attack graph to build the structure of the MDP model and performs many Bayesian queries to calculate the probabilities of the MDP model. Moreover, the number of exploit nodes in the attack graph grows linearly as the size of the attack graph increases, since each added host adds a certain number of exploits to the substation (at least one zero-day and a limited number of known exploits).

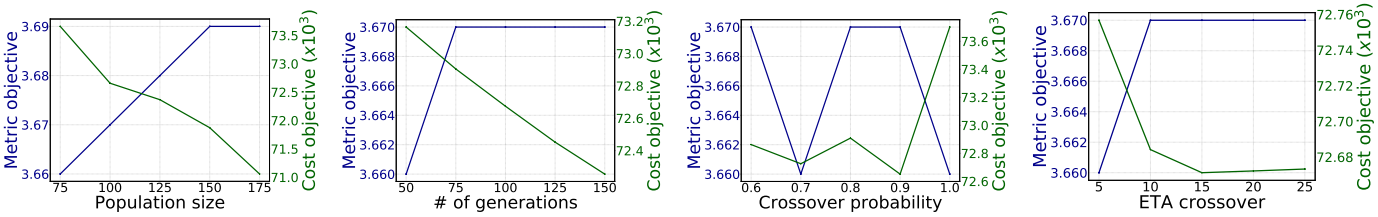
NH execution time.

Fig. 18c shows that although the time required by the NH module grows almost linearly with the number of hosts, it remains around 500 seconds for attack graphs with 40 hosts, which demonstrates the applicability of our approach to cases where there is a need for timely hardening decisions. Moreover, the number of hardening possibilities grows exponentially with the size of the attack graph (the right y-axis shows in logarithmic scale the number of possible hardening vectors for the sake of readability). For instance, even for substations with as few as five hosts, the number of possible hardening vectors is around 2^{46}, and therefore identifying the optimal hardening using brute force is impractical in a real-world substation, which demonstrates the usefulness of an efficient optimization algorithm such as NSGA-II in HFS.

VI. Related Work

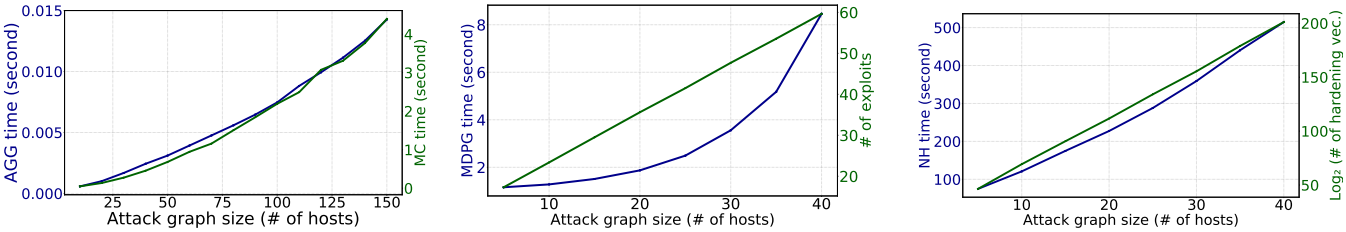
Supply chain security is an increasingly important topic for smart grids. In [35], the authors develop a decision framework that facilitates the selection of vendors to mitigate supply chain attacks. In [7], the authors leverage cyber threat intelligence to identify threats to the cyber supply chain. In [36], the authors determine the probability of attacks against the cyber supply chain using Bayesian belief networks, and in [37], the authors adopt a multiscale approach to improve the resilience of the supply chain through the life cycle of systems. In [38], the authors propose a method for detecting counterfeit devices. In [6], the authors define a formal supply chain security metric that measures the security posture of substations against supply chain attacks. In contrast, in this paper, we develop a hardening system that aims to both improve the security metrics and decrease the hardening costs.

Attack graphs, threat modeling, security metrics, and network hardening have been extensively studied in the literature [6], [8], [9], [17], [19], [20], [28], [39]–[41]. The existing attack graph generation tools (e.g., MULVAL [39] and CAULDRON [40]) do not consider supply chain vulnerabilities. For



(a) Effect of population size. (b) Effect of the # of generations. (c) Effect of crossover probability. (d) Effect of ETA values.

Fig. 17: Evaluating metrics and cost objectives with different optimization parameters.



(a) AGG and MC delay. (b) MDPG delay and # of exploits. (c) NH delay and # of hardening vectors.

Fig. 18: Execution time of HC modules for different sizes of attack graphs.

threat modeling, [28] extends power system contingency analysis to include contingencies caused by compromises. In [9], the authors demonstrate that the reliability of power systems decreases as the skill levels of attackers increase. In [8], the authors define security metrics for measuring the effectiveness of *redundant* subsystems from the security perspective and conclude that diversity can improve security for redundant subsystems. In [17], the authors formally define the diversity of service instances in the network as a security metric. In [41], the authors apply genetic algorithms to improve the security posture of critical networks using diversity. In [20], the authors extend [41] by considering more hardening options, such as activating firewalls. In [19], the authors formulate the optimization problem of diversifying network services under cost constraints using different diversity metrics. In [42], the authors apply network hardening to mitigate security threats in network function virtualization, and [43] adopts multi-objective optimization for improving the security of dynamic networks based on heterogeneous hardening options. In [44], the authors claim that gradient descent search outperforms genetic algorithms for network hardening without specifying the hardening options that should be utilized. In contrast to those general-purpose hardening approaches, HFS focuses on combining supply chain-related and non-supply chain-related hardening options for improving the security posture of IEC 61850 substations against supply chain attacks.

VII. Conclusion

In this paper, we present a hardening system for improving the security posture of smart grid substations against supply chain attacks. We combine supply chain-related and non-supply-chain-related hardening options under the same framework, which renders our approach applicable to cases where it is infeasible to address supply chain vulnerabilities. We formulated and solved the problem of hardening substations under operational and cost constraints using multi-objective optimization. Our simulation results demonstrate that HFS is able to effectively improve the security posture of substations against supply chain attacks under different constraints, and it has an acceptable execution time even for large substations. In the future, we plan to deploy HFS in real-world substations and integrate it with real-time power system simulators (such as Hypersim [45]).

Acknowledgement

The authors thank the anonymous reviewers for their valuable comments. The research reported in this paper is funded by the NSERC/Hydro-Québec Thales Research Chair in Smart Grid Security and the NSERC Discovery Grant N01035.

References

[1] J. Yan, Y. Zhu, H. He, and Y. Sun, "Multi-contingency cascading analysis of smart grid based on self-organizing map," *IEEE Transactions on Information Forensics and Security*, vol. 8, no. 4, pp. 646–656, 2013.

[2] "Analysis of the Cyber Attack on the Ukrainian Power Grid." https://www.sans.org/webcasts/analyzing-ukrainian-power-grid-cyber-attacks-102007. [Online; Accessed 29-May-2021].

[3] H. C. Tan, C. Cheh, B. Chen, and D. Mashima, "Tabulating cybersecurity solutions for substations: Towards pragmatic design and planning," in *2019 IEEE Innovative Smart Grid Technologies-Asia (ISGT Asia)*, pp. 1018–1023, IEEE, 2019.

[4] O. Duman, L. Wang, M. Au, M. Kassouf, and M. Debbabi, "Hardening substations against supply chain attacks under operational constraints," in *2022 IEEE Power & Energy Society Innovative Smart Grid Technologies Conference (ISGT)*, pp. 1–5, IEEE, 2022.

[5] "Analysis of the Cyber Attack on the Ukrainian Power Grid." https://www.sans.org/blog/what-you-need-to-know-about-the-solarwinds-supply-chain-attack/. [Online; Accessed 29-May-2021].

[6] O. Duman, M. Ghafouri, M. Kassouf, R. Atallah, L. Wang, and M. Debbabi, "Modeling supply chain attacks in iec 61850 substations," in *2019 IEEE International Conference on Communications, Control, and Computing Technologies for Smart Grids (SmartGridComm)*, pp. 1–6, IEEE, 2019.

[7] A. Yeboah-Ofori and S. Islam, "Cyber security threat modeling for supply chain organizational environments," *future internet*, vol. 11, no. 3, p. 63, 2019.

[8] O. Duman, M. Zhang, L. Wang, M. Debbabi, R. Atallah, and B. Lebel, "Factor of security (fos): Quantifying the security effectiveness of redundant smart grid subsystems," *IEEE Transactions on Dependable and Secure Computing*, 2020.

[9] Y. Zhang, L. Wang, Y. Xiang, and C.-W. Ten, "Power system reliability evaluation with scada cybersecurity considerations," *IEEE Transactions on Smart Grid*, vol. 6, no. 4, pp. 1707–1721, 2015.

[10] E. D. Knapp and R. Samani, *Applied cyber security and the smart grid: implementing security controls into the modern power infrastructure*. Newnes, 2013.

[11] L. Wang, S. Jajodia, A. Singhal, P. Cheng, and S. Noel, "k-zero day safety: A network security metric for measuring the risk of unknown vulnerabilities," *IEEE Transactions on Dependable and Secure Computing*, vol. 11, no. 1, pp. 30–44, 2013.

[12] P. Ammann, D. Wijesekera, and S. Kaushik, "Scalable, graph-based network vulnerability analysis," in *Proceedings of the 9th ACM Conference on Computer and Communications Security*, pp. 217–224, 2002.

[13] O. Sheyner, J. Haines, S. Jha, R. Lippmann, and J. M. Wing, "Automated generation and analysis of attack graphs," in *Proceedings 2002 IEEE Symposium on Security and Privacy*, pp. 273–284, IEEE, 2002.

[14] K. Scarfone and P. Mell, "An analysis of cvss version 2 vulnerability scoring," in *2009 3rd International Symposium on Empirical Software Engineering and Measurement*, pp. 516–525, IEEE, 2009.

[15] "CVE-2015-4555 Detail." https://nvd.nist.gov/vuln/detail/CVE-2015-4555. [Online; accessed 15-January-2022].

[16] W. Nzoukou, L. Wang, S. Jajodia, and A. Singhal, "A unified framework for measuring a network's mean time-to-compromise," in *2013 IEEE 32nd International Symposium on Reliable Distributed Systems*, pp. 215–224, IEEE, 2013.

[17] M. Zhang, L. Wang, S. Jajodia, A. Singhal, and M. Albanese, "Network diversity: a security metric for evaluating the resilience of networks against zero-day attacks," *IEEE Transactions on Information Forensics and Security*, vol. 11, no. 5, pp. 1071–1086, 2016.

[18] "Common Criteria." https://www.commoncriteriaportal.org/. [Online; accessed 23-January-2021].

[19] D. Borbor, L. Wang, S. Jajodia, and A. Singhal, "Optimizing the network diversity to improve the resilience of networks against unknown attacks," *Computer Communications*, vol. 145, pp. 96–112, 2019.

[20] D. Borbor, L. Wang, S. Jajodia, and A. Singhal, "Securing networks against unpatchable and unknown vulnerabilities using heterogeneous hardening options," in *IFIP Annual Conference on Data and Applications Security and Privacy*, pp. 509–528, Springer, 2017.

[21] L. Wang, T. Islam, T. Long, A. Singhal, and S. Jajodia, "An attack graph-based probabilistic security metric," in *Data and Applications Security XXII: 22nd Annual IFIP WG 11.3 Working Conference on Data and Applications Security London, UK, July 13-16, 2008 Proceedings 22*, pp. 283–296, Springer, 2008.

[22] "63% of organizations face security breaches due to hardware vulnerabilities." https://www.techrepublic.com/article/63-of-organizations-face-security-breaches-due-to-hardware-vulnerabilities/. [Online; Accessed 29-May-2021].

[23] "Majority of 2019 breaches were the result of unapplied security patches." https://www.helpnetsecurity.com/2019/10/30/unapplied-security-patches/. [Online; Accessed 29-May-2021].

[24] R. Dewri, N. Poolsappasit, I. Ray, and D. Whitley, "Optimal security hardening using multi-objective optimization on attack tree models of networks," in *Proceedings of the 14th ACM conference on Computer and communications security*, pp. 204–213, 2007.

[25] L. Mieritz and B. Kirwin, "Defining gartner total cost of ownership," *L. Mieritz, B. Kirwin*, 2005.

[26] "Network Firewalls Pricing Comparison." https://www.trustradius.com/buyer-blog/network-firewall-pricing-comparison. [Online; Accessed 29-May-2021].

[27] J. Blank and K. Deb, "pymoo: Multi-objective optimization in python," *IEEE Access*, vol. 8, pp. 89497–89509, 2020.

[28] S. Zonouz, C. M. Davis, K. R. Davis, R. Berthier, R. B. Bobba, and W. H. Sanders, "Socca: A security-oriented cyber-physical contingency analysis in power infrastructures," *IEEE Transactions on Smart Grid*, vol. 5, no. 1, pp. 3–13, 2013.

[29] K. R. Davis, C. M. Davis, S. A. Zonouz, R. B. Bobba, R. Berthier, L. Garcia, and P. W. Sauer, "A cyber-physical modeling and assessment framework for power grid infrastructures," *IEEE Transactions on smart grid*, vol. 6, no. 5, pp. 2464–2475, 2015.

[30] P. Akaber, B. Moussa, M. Ghafouri, R. Atallah, B. L. Agba, C. Assi, and M. Debbabi, "Cases: concurrent contingency analysis-based security metric deployment for the smart grid," *IEEE Transactions on Smart Grid*, vol. 11, no. 3, pp. 2676–2687, 2019.

[31] R. S. Sutton and A. G. Barto, *Reinforcement learning: An introduction*. MIT press, 2018.

[32] L. Thurner, A. Scheidler, F. Schafer, J. H. Menke, J. Dollichon, F. Meier, S. Meinecke, and M. Braun, "pandapower - an open source python tool for convenient modeling, analysis and optimization of electric power systems," *IEEE Transactions on Power Systems*, 2018.

[33] "How much does a server cost for a small business?." https://www.serverpronto.com/spu/2019/04/how-much-does-a-server-cost-for-a-small-business/. [Online; Accessed 29-May-2021].

[34] K. Deb, K. Sindhya, and T. Okabe, "Self-adaptive simulated binary crossover for real-parameter optimization," in *Proceedings of the 9th annual conference on genetic and evolutionary computation*, pp. 1187–1194, 2007.

[35] T. Kieras, J. Farooq, and Q. Zhu, "I-scram: A framework for iot supply chain risk analysis and mitigation decisions," *IEEE Access*, vol. 9, pp. 29827–29840, 2021.

[36] A. Yeboah-Ofori, S. Islam, and A. Brimicombe, "Detecting cyber supply chain attacks on cyber physical systems using bayesian belief network," in *2019 International Conference on Cyber Security and Internet of Things (ICSIoT)*, pp. 37–42, IEEE, 2019.

[37] J. H. Lambert, J. M. Keisler, W. E. Wheeler, Z. A. Collier, and I. Linkov, "Multiscale approach to the security of hardware supply chains for energy systems," *Environment Systems and Decisions*, vol. 33, no. 3, pp. 326–334, 2013.

[38] L. Babun, H. Aksu, and A. S. Uluagac, "Identifying counterfeit smart grid devices: A lightweight system level framework," in *2017 IEEE International Conference on Communications (ICC)*, pp. 1–6, IEEE, 2017.

[39] X. Ou, S. Govindavajhala, and A. W. Appel, "Mulval: A logic-based network security analyzer.," in *USENIX security*, 2005.

[40] S. Jajodia, S. Noel, P. Kalapa, M. Albanese, and J. Williams, "Cauldron mission-centric cyber situational awareness with defense in depth," in *2011-MILCOM 2011 Military Communications Conference*, pp. 1339–1344, IEEE, 2011.

[41] D. Borbor, L. Wang, S. Jajodia, and A. Singhal, "Diversifying network services under cost constraints for better resilience against unknown attacks," in *IFIP Annual Conference on Data and Applications Security and Privacy*, pp. 295–312, Springer, 2016.

[42] N. Alhebaishi, L. Wang, and S. Jajodia, "Modeling and mitigating security threats in network functions virtualization (nfv)," in *Data and Applications Security and Privacy XXXIV: 34th Annual IFIP WG 11.3 Conference, DBSec 2020, Regensburg, Germany, June 25–26, 2020, Proceedings 34*, pp. 3–23, Springer, 2020.

[43] S. Y. Enoch, J. Mendonça, J. B. Hong, M. Ge, and D. S. Kim, "An integrated security hardening optimization for dynamic networks using security and availability modeling with multi-objective algorithm," *Computer Networks*, vol. 208, p. 108864, 2022.

[44] K. Zenitani, "A multi-objective cost–benefit optimization algorithm for network hardening," *International Journal of Information Security*, vol. 21, no. 4, pp. 813–832, 2022.

[45] "Hypersim." http://www.hydroquebec.com/innovation/en/pdf/2010G080-16A-Hypersim.pdf. [Online; accessed 28-February-2023].